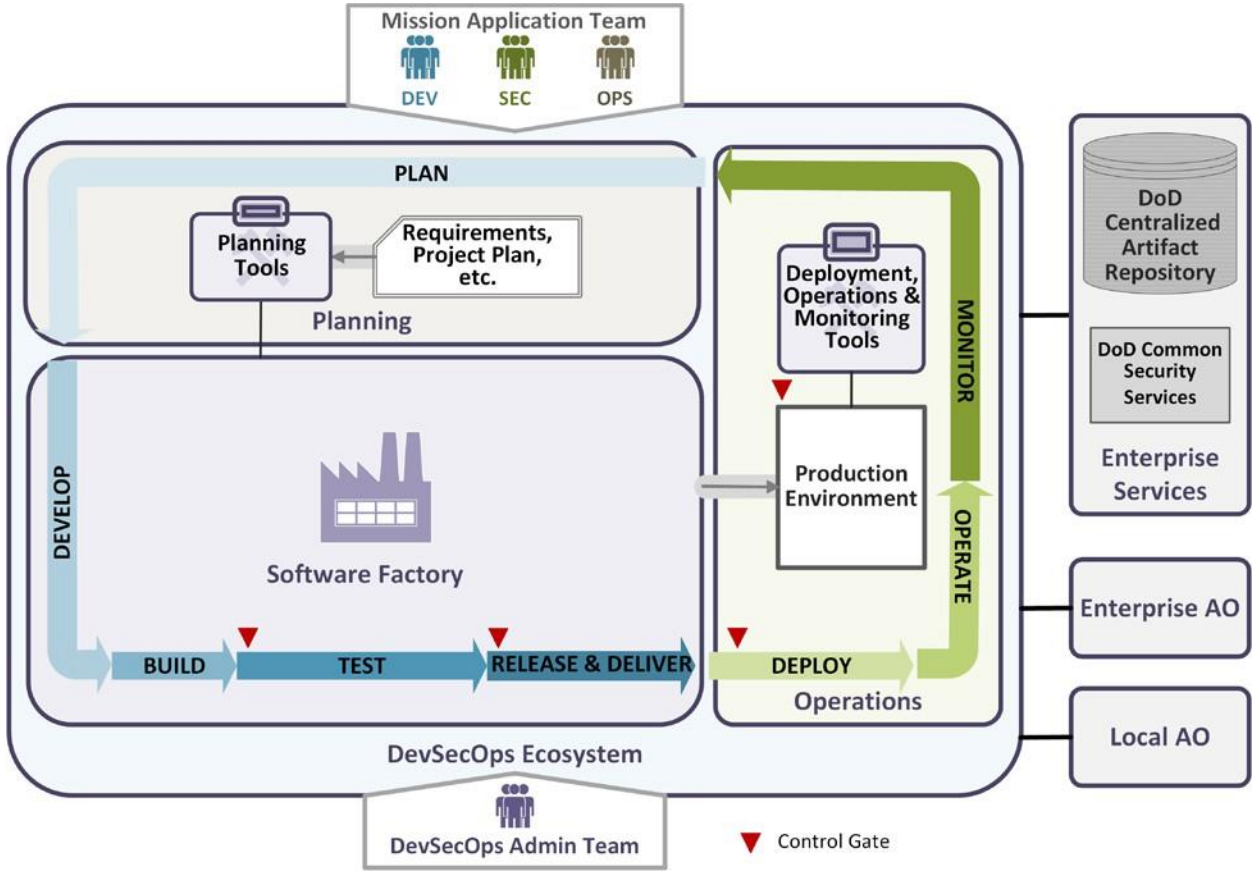
DevSecOps ecosystem, workflows, and pipelines

DevSecOps ecosystem

The **DevSecOps ecosystem** is a collection of tools, and the process workflows created and executed on the tools to support all the activities throughout the full DevSecOps lifecycle.

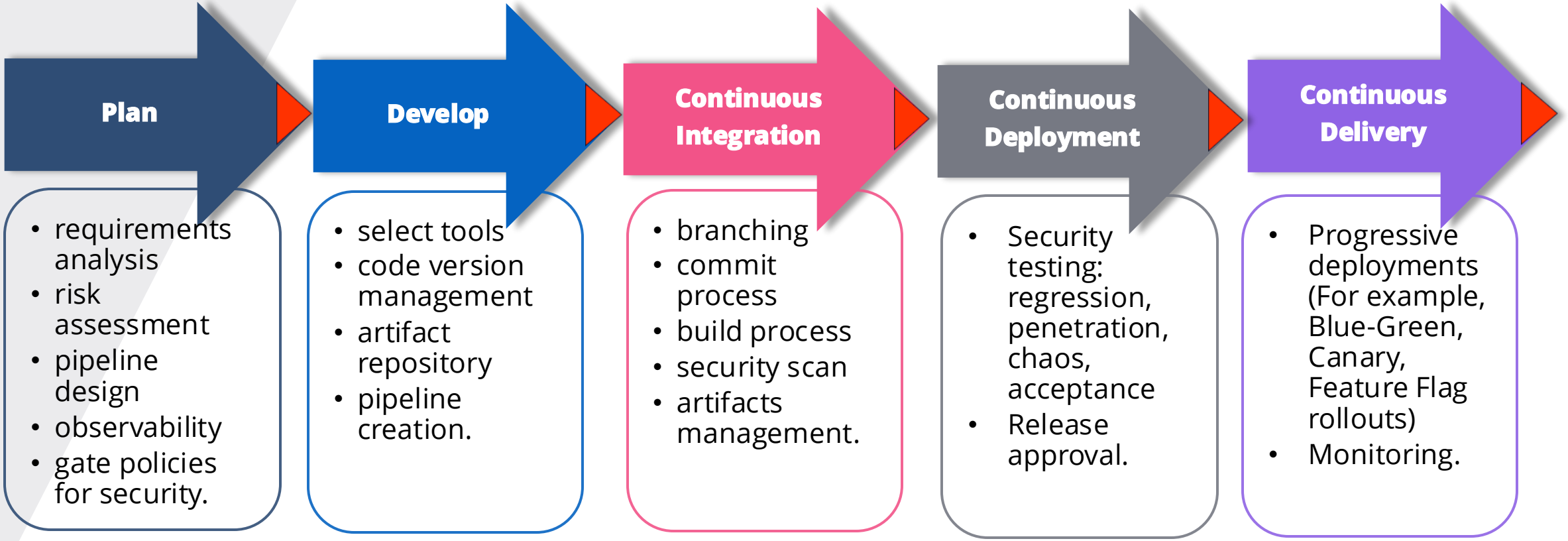
The DevSecOps ecosystem is composed of three subsystems: **planning**, **DevSecOps pipeline tools**, and **production operations**.



Source: https://dodcio.defense.gov/Portals/0/Documents/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20v1.0_Public%20Release.pdf

Copyright© 2025 PeopleCert International Ltd.

DevSecOps workflows



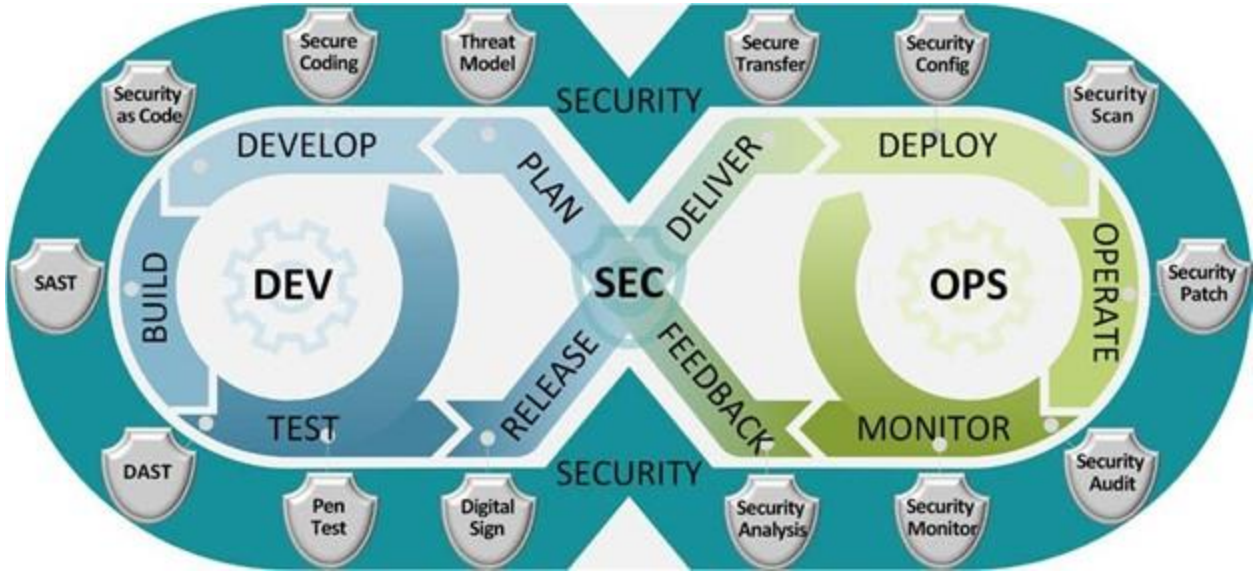
Process gate

Copyright© 2025 PeopleCert International Ltd.

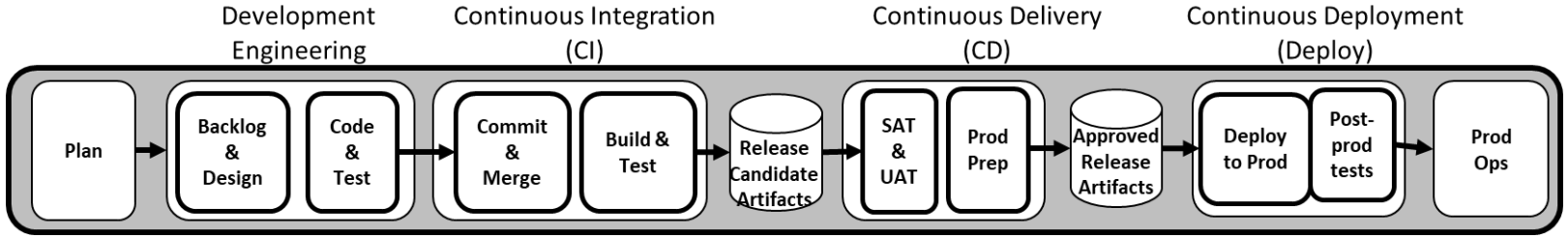
DevSecOps pipelines

The DevSecOps pipeline

- Is automated.
- Is visible.
- Creates Continuous Integration, Delivery, Deployment, feedback, operations.
- Allows cohesive work across multiple physical and logical areas.
- Loops run in both directions.
- Pipelines create one way flow with feedback.
- Phases
  - Plan.
  - Develop.
  - Build.
  - Test.
  - Deploy.
  - Monitor.



Source: https://dodcio.defense.gov/Portals/0/Documents/DoD%20Enterprise%20DevSecOps%20Reference%20Design%20v1.0_Public%20Release.pdf



Source: *Engineering DevOps by Marc Hornbeek* https://mybook.to/engineeringdevops

Copyright© 2025 PeopleCert International Ltd.

Source control

Version control

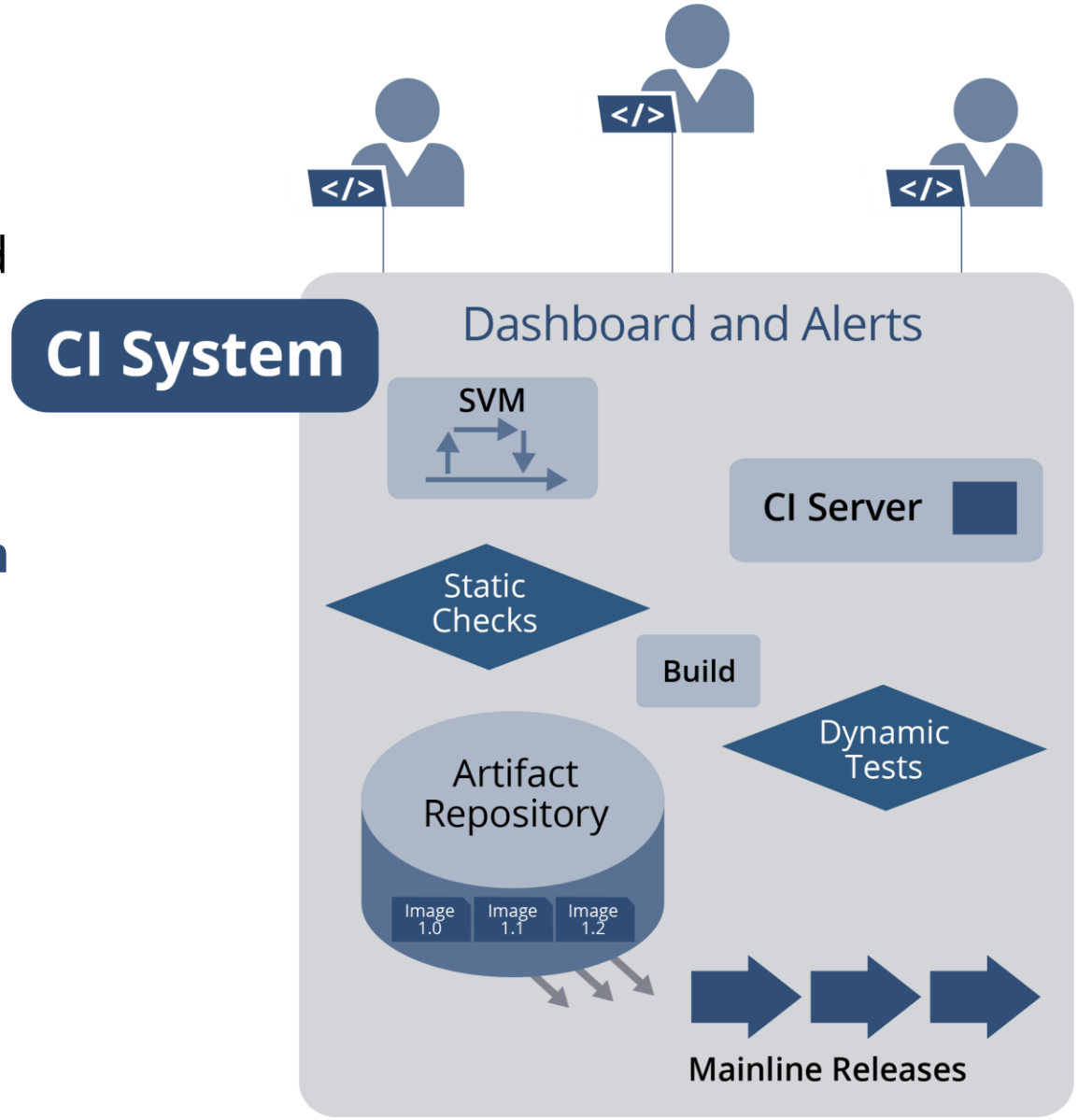
- Continuous Integration (CI) system/tool used to store/track changes of code and artifacts in source version management (SVM) and artifact repositories.

Track changes over time and allow reversion

- branches
- trunk
- merges.

Allows multiple coders simultaneously

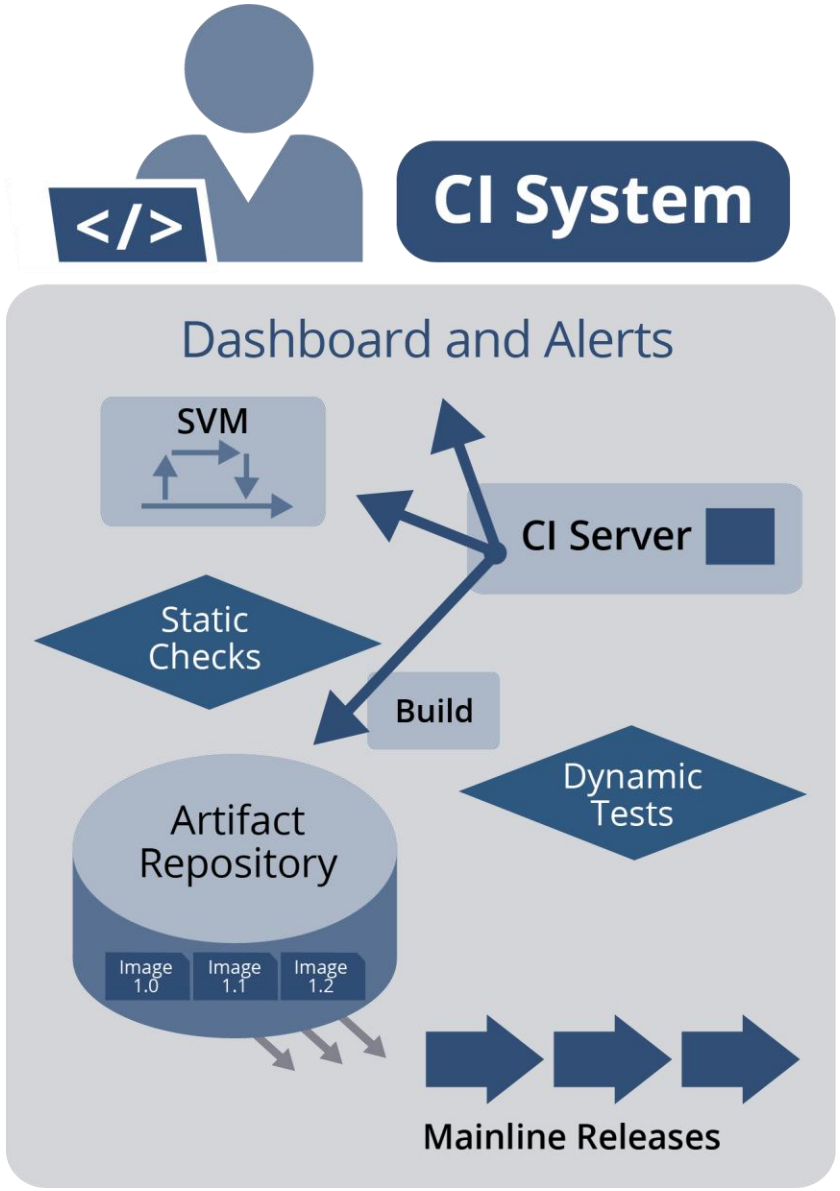
- Merge commits from multiple developers.
- Accelerates change management.
- Allows for increased traceability.



Copyright© 2025 PeopleCert International Ltd.

How does CI work? Images, merges, reports

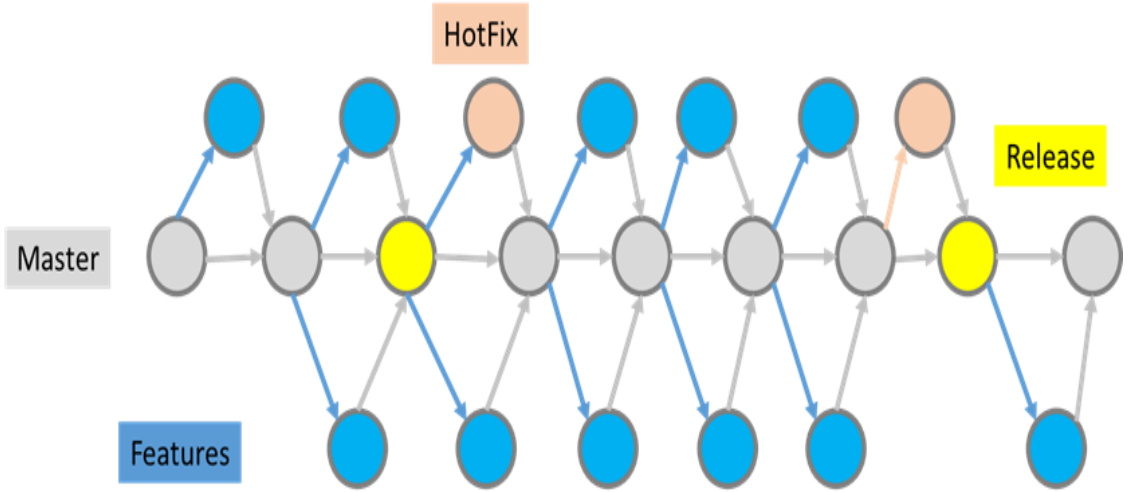
- Images that pass the tests are stored in an Artifact Repository as potential release candidates.
- The verified code changes are merged into the mainline code in the SVM.
- All the steps are made visible in a dashboard.
- Pull request is accepted.
- Any exceptions or failures are reported in alert messages.



Copyright© 2025 PeopleCert International Ltd.

‘No Feature Branches’ best practice

- There are no separate feature branches.
- Merge when code is pulled from mainline (trunk branch).
- Branch in-code (within mainline) using feature toggles (that is, configuration flags).
- Eliminates merging issues and keeps everyone accountable.
- Is simple and easy to understand.



Trunk based branching with Feature Flags
Adapted from: https://dev.to/juniourrau/6-types-of-git-branching-strategy-g54

Copyright© 2025 PeopleCert International Ltd.

Optimizing the pipeline

Fix the common problems

Example one: DevOps and CI/CD are not the same; cultural versus technological.

Example two: only thinking about Dev and Ops; still uses silos.

Example three: stuck branches due to pull requests, storage limits, ownership, or tool challenges; process challenge.

Example four: observability, code coverage and review does not happen; cultural quality issue.

Fix the challenging problems

Example one: no quality emphasis, remember Lean; process.

Example two: lack of dashboards and reporting; technical.

Example three: multiple templates at scale; process.

Example four: inefficient Implementation; technical.



Copyright© 2025 PeopleCert International Ltd.

DevSecOps maturity model

DevSecOps Maturity Level	People Practices	Process Practices	Technology Practices
Level 1 Chaos	Silo team organization, Little knowledge of DevSecOps practices, Blame, finger-pointing	Security not part of planning Few security checks as part of DevOps pipeline.	Missing tools to monitor security of applications, pipelines and infrastructure
Level 2 Continuous Integration (CI)	Limited knowledge of DevSecOps, Some security task in backlog, Ad hoc security training, Security consultants	Lack of E2E security plan, Repeatable build process with security checks , Most commits pass security code static analysis tests, Secrets vaulted	Version Management, Pre-flight and commit processes include security checks, such as static analysis, white lists and security tests, Painful but repeatable releases
Level 3 Continuous Flow	Leaders articulate a DevSecOps vision, Cross-function participation in s DevSecOPs skills, Training program, Risk management culture	E2E Apps, CI/CD pipeline, and Infra availability security vulnerabilities visible, Security standards and protocols, Security event response time metrics	Toolchains w/ security tools APIs and tests, Signed artifacts, Filtered event streams for app, infra, pipeline, Release and Deploy w/security metrics.
Level 4 Continuouos Feedback	Collaboration using shared security metrics , Goals: SLI/O/As include security, Mentors and Guilds for mastering security, Recognition programs	Pro-active trends analysis visible for security, Security warnings trigger actions, Red/Blue teams	Apps, pipelines and infra instrumented for security, Infra & config “as-code”, Releases automated w/ security policies, Value stream analytics for end-to-end security
Level 5 Continuous Improvement	Experimentation, High level of security confidence, SREs in development , E2E security experience	Consolidated security metrics, Monitor security outliers, not just averages, Insights into threats made visible to stakeholders, Security Chaos testing	Security Algorithms, Synthetic security monitoring, Intelligent security analytics E.g. AISecOPs

Copyright© 2025 PeopleCert International Ltd.

Source: www.engineeringdevops.com